“Año de la recuperación y consolidación de la economía peruana”

UNIVERSIDAD PRIVADA ANTENOR ORREGO

FACULTAD DE INGENIERÍA

ESCUELA DE INGENIERÍA DE SISTEMAS E INTELIGENCIA ARTIFICIAL

“ÉTICA_SEGURIDAD DE DATOS_S11”

ISO/IEC 27001, ISO/IEC 27701, Ley de Protección de Datos Personales, plan de contingencia con IA alineado a los ODS y ensayo sobre la ciberdelincuencia en el Perú

CURSO: SISTEMAS DE INFORMACIÓN INTEGRADOS

NRC: 12054 (Teoría) – 12055 (Laboratorio)

DOCENTE: Dr. Mendoza Corpus Carlos Alfredo

ESTUDIANTE: Carranza Jacinto Juan Diego

ID: 000257022

TRUJILLO – PERÚ

2026

Introducción

El presente trabajo individual aborda la ética y la seguridad de los datos desde tres planos complementarios: el normativo, el técnico y el social. En el plano normativo se revisan dos estándares internacionales, ISO/IEC 27001 para la gestión de la seguridad de la información e ISO/IEC 27701 para la gestión de la privacidad, junto con la Ley N.° 29733, Ley de Protección de Datos Personales del Perú, y su nuevo reglamento. En cada caso se resume el contenido, se describe su aplicación actual y se identifican organizaciones o casos concretos documentados en fuentes públicas.

En el plano técnico se elabora, con apoyo de inteligencia artificial generativa, una propuesta de plan de contingencia para una infraestructura tecnológica; la salida inicial de la IA se evalúa críticamente frente a los Objetivos de Desarrollo Sostenible (ODS) y a normas internacionales, y se ajusta hasta obtener una versión final verificable. En el plano social se alinea cada uno de los diecisiete ODS con el propósito de la carrera de Ingeniería de Sistemas e Inteligencia Artificial y se presentan dos ensayos sobre los capítulos I y II del Informe Defensorial «La ciberdelincuencia en el Perú: estrategias y retos del Estado».

Los datos sobre empresas, sanciones y certificaciones proceden de comunicados oficiales, resoluciones, certificados publicados y prensa especializada que se citan en las referencias. El material de soporte del plan de contingencia (prompt, salida original de la IA, evaluación, versión ajustada y programa de la matriz de riesgos) se encuentra en el repositorio indicado en la sección final.

Parte I. Norma ISO/IEC 27001

1.1. Resumen de la norma

ISO/IEC 27001 es la norma internacional que establece los requisitos para implantar, mantener y mejorar de forma continua un Sistema de Gestión de Seguridad de la Información (SGSI). Su propósito es preservar la confidencialidad, la integridad y la disponibilidad de la información mediante un proceso de gestión de riesgos, de modo que la organización demuestre a clientes, reguladores y socios que sus riesgos de información están identificados y tratados. La edición vigente es ISO/IEC 27001:2022, complementada por la enmienda ISO/IEC 27001:2022/Amd 1:2024, que exige considerar el cambio climático como una cuestión pertinente del contexto de la organización (AFNOR, s. f.; Bright Defense, 2026).

La norma sigue la estructura armonizada de los sistemas de gestión ISO y se organiza en dos partes. La primera son las cláusulas 4 a 10, que son obligatorias y siguen el ciclo planificar-hacer-verificar-actuar:

Cláusula	Contenido principal
4. Contexto	Cuestiones internas y externas, partes interesadas y sus requisitos, alcance del SGSI.
5. Liderazgo	Compromiso de la alta dirección, política de seguridad de la información, roles y responsabilidades.
6. Planificación	Evaluación y tratamiento de riesgos, Declaración de Aplicabilidad (SoA) y objetivos de seguridad.
7. Apoyo	Recursos, competencia, concienciación, comunicación e información documentada.
8. Operación	Ejecución de la evaluación y del plan de tratamiento de riesgos.
9. Evaluación del desempeño	Seguimiento, medición, auditoría interna y revisión por la dirección.
10. Mejora	No conformidades, acciones correctivas y mejora continua.

Tabla 1. Cláusulas obligatorias de ISO/IEC 27001:2022.

La segunda parte es el Anexo A, un catálogo de 93 controles agrupados en cuatro temas: organizacionales (37), de personas (8), físicos (14) y tecnológicos (34). La edición de 2022 incorporó 11 controles nuevos, entre ellos inteligencia de amenazas (A.5.7), seguridad en el uso de servicios en la nube (A.5.23), preparación de las TIC para la continuidad del negocio (A.5.30), gestión de la configuración (A.8.9), eliminación de información (A.8.10), enmascaramiento de datos (A.8.11), prevención de fuga de datos (A.8.12), actividades de monitoreo (A.8.16) y codificación segura (A.8.28). La organización no está obligada a aplicar todos los controles: debe justificar en la Declaración de Aplicabilidad cuáles aplica y por qué, en función de su evaluación de riesgos. El período de transición desde la versión de 2013 concluyó el 31 de octubre de 2025, por lo que hoy toda certificación vigente corresponde a la edición de 2022.

1.2. Aplicación en la actualidad

ISO/IEC 27001 es una de las normas de sistemas de gestión con mayor crecimiento en el mundo. Según el ISO Survey 2024, existían 96 709 certificados válidos que cubrían 179 877 sitios, un aumento cercano al 65 % respecto de 2021, y el sector de tecnologías de la información es el que más la utiliza (AFNOR, s. f.; Bright Defense, 2026; Speeki, s. f.). Su adopción se explica por cuatro motivos. Primero, se ha convertido en un requisito contractual: bancos, aseguradoras, entidades públicas y grandes empresas exigen la certificación a sus proveedores de software, nube, centros de datos y tercerización. Segundo, ofrece una base común para cumplir regulaciones de protección de datos y de ciberseguridad, porque sus controles se pueden mapear con la Ley N.° 29733, el RGPD europeo o la directiva NIS2. Tercero, el aumento de los ataques de ransomware y de las filtraciones obliga a gestionar el riesgo de forma sistemática y no reactiva. Cuarto, la enmienda de 2024 extiende su alcance a riesgos climáticos que afectan la disponibilidad de la infraestructura.

En el Perú existe la norma técnica equivalente NTP-ISO/IEC 27001:2022, y el Instituto Nacional de Calidad (Inacal) implementó un esquema de acreditación para los organismos que certifican sistemas de gestión de seguridad de la información (Andina, s. f.-a). En el sector público, la Secretaría de Gobierno y Transformación Digital exige a las entidades implementar un SGSI basado en esta norma técnica. En el sector privado destaca el papel de ProInnóvate, programa del Ministerio de la Producción, que cofinancia la implementación en empresas medianas y emergentes, como se observa en los casos de Tkambio y Yarkan (Gestión, s. f.; Cámara de Comercio de Lima, s. f.).

1.3. Empresas que usan la norma

Organización	Sector	Uso de la norma y alcance documentado
Kyndryl Perú S.A.C.	Servicios de infraestructura de TI	Certificado ISO/IEC 27001:2022 publicado por la compañía, con vigencia hasta febrero de 2028. Respalda los servicios gestionados de infraestructura que presta a clientes corporativos en el país (Kyndryl, 2024).
Cirion Technologies Perú S.A.	Centros de datos y nube	El centro de datos LIM1 (Av. Manuel Olguín, Lima) opera bajo un SGSI certificado, sobre el cual además obtuvo la certificación de privacidad ISO/IEC 27701 para sus servicios de hosting virtual (Cirion Technologies, 2024).
Organismo Supervisor de las Contrataciones del Estado (OSCE)	Sector público	Certificó su SGSI bajo ISO 27001 con TÜV Rheinland, con un alcance de siete procesos misionales; previamente contaba con ISO 37001 e ISO 9001 (Andina, s. f.-b).
Rextie	Fintech, casa de cambio en línea	Obtuvo la certificación para respaldar la confidencialidad, integridad y disponibilidad de los datos de sus usuarios y el cumplimiento legal de sus operaciones cambiarias digitales (Revista Economía, s. f.).
Tkambio	Fintech, casa de cambio digital	Certificó su SGSI tras una implementación de unos seis meses que involucró a toda la organización, con fondos no reembolsables de ProInnóvate (Gestión, s. f.).
Yarkan S.A.C.	Servicios empresariales	Implementó y certificó un SGSI para identificar, gestionar y mitigar riesgos sobre la información corporativa, también con apoyo de ProInnóvate (Cámara de Comercio de Lima, s. f.).
Google Cloud, Microsoft Azure y Amazon Web Services	Nube pública global	Mantienen certificaciones ISO/IEC 27001 sobre sus servicios y las usan como base para certificaciones adicionales de privacidad (ISO/IEC 27701) que ofrecen a sus clientes (Google Cloud, 2020; Microsoft, 2020; Amazon Web Services, s. f.).

Tabla 2. Organizaciones que aplican ISO/IEC 27001. Elaboración propia a partir de las fuentes citadas.

Parte II. Norma ISO/IEC 27701

2.1. Resumen de la norma

ISO/IEC 27701 especifica los requisitos para establecer, implementar, mantener y mejorar un Sistema de Gestión de la Información de Privacidad (PIMS, por sus siglas en inglés). Su objeto es la protección de la información de identificación personal (PII), es decir, cualquier dato que permita identificar a una persona natural, y se aplica tanto a los responsables del tratamiento (que deciden para qué y cómo se tratan los datos) como a los encargados (que los tratan por cuenta de otro).

La primera edición, de 2019, se concibió como una extensión de ISO/IEC 27001 e ISO/IEC 27002: añadía requisitos de privacidad a un SGSI existente y no podía certificarse por sí sola. El 14 de octubre de 2025 ISO e IEC publicaron la segunda edición, ISO/IEC 27701:2025, que la convierte en una norma de sistema de gestión independiente (DNV, s. f.; Coalfire, 2026). Sus principales cambios son los siguientes:

- Tiene cláusulas propias de la 4 a la 10 con la estructura armonizada que comparten ISO/IEC 27001:2022 e ISO/IEC 42001, incluida una evaluación de riesgos de privacidad específica en la cláusula 6 (Linford & Co., 2026).
- Ya no exige la certificación ISO/IEC 27001 como requisito previo, aunque ambas pueden integrarse en un solo sistema de gestión (ISMS.online, s. f.).
- Su Anexo A contiene alrededor de 78 controles de privacidad organizados en tres tablas: controles para responsables, controles para encargados y controles comunes a ambos roles (ISMS.online, s. f.).
- Se publicó junto con ISO/IEC 27706:2025, que fija los requisitos para los organismos que auditan y certifican un PIMS (A-LIGN, s. f.).
- Las organizaciones certificadas con la edición de 2019 deben completar la transición antes del 31 de octubre de 2028 (Coalfire, 2026).

Los controles cubren todo el ciclo de vida del dato personal: identificación de la base legal y de la finalidad, consentimiento, evaluaciones de impacto en la privacidad, minimización, atención de los derechos de los titulares, transferencias internacionales, contratos con encargados, notificación de brechas y eliminación de la información al terminar el tratamiento. Por ello sirve como evidencia de cumplimiento frente a leyes como el RGPD europeo o la Ley N.° 29733 peruana, aunque la certificación no sustituye la obligación legal.

2.2. Aplicación en la actualidad

La adopción de ISO/IEC 27701 está concentrada en organizaciones que tratan datos personales de terceros a gran escala: proveedores de nube, centros de datos, empresas de software como servicio, tercerizadoras de procesos y servicios financieros. Para ellas la certificación funciona como prueba verificable ante clientes que deben auditar a sus encargados de tratamiento, y reduce el número de auditorías independientes en cadenas de suministro con flujos de datos transfronterizos (Microsoft, 2020). La edición de 2025 amplía el mercado potencial, porque una organización puede certificar su gestión de privacidad sin implantar antes un SGSI completo.

En el Perú la norma tiene una adopción todavía inicial, pero su relevancia crece por el nuevo Reglamento de la Ley N.° 29733, vigente desde el 31 de marzo de 2025, que introdujo obligaciones como la designación del oficial de datos personales y la notificación de incidentes de seguridad (Payet, Rey, Cauvi, Pérez Abogados, 2026). Programas de formación como el del Instituto para la Calidad de la PUCP, que combina ISO/IEC 27001, ISO/IEC 27701 y la función de oficial de datos personales, muestran que el mercado comienza a demandar este perfil (Pontificia Universidad Católica del Perú, 2026).

2.3. Empresas que usan la norma

Organización	Rol frente a los datos	Uso de la norma y alcance documentado
Google Cloud	Encargado del tratamiento	Fue el primer gran proveedor de nube en obtener una certificación acreditada ISO/IEC 27701 como encargado del tratamiento, emitida por Coalfire ISO en 2020. Hoy cubre Google Cloud y Google Workspace, y sus clientes pueden usar el certificado en sus propios programas de cumplimiento (Google Cloud, 2020; Google Cloud, s. f.).
Microsoft Azure	Encargado del tratamiento	Primer proveedor de nube estadounidense en certificarse como encargado bajo ISO/IEC 27701, con certificado emitido por Schellman & Company. Lo presenta como apoyo para que sus clientes demuestren cumplimiento del RGPD (Microsoft, 2020).

Organización	Rol frente a los datos	Uso de la norma y alcance documentado
Amazon Web Services	Encargado del tratamiento	Mantiene la certificación ISO/IEC 27701 para los servicios y regiones incluidos en su alcance, y aplica los controles a todo el contenido de los clientes, sea o no dato personal (Amazon Web Services, s. f.).
Cirion Technologies Perú S.A.	Encargado del tratamiento	Su centro de datos LIM1 en Lima cuenta con certificado ISO/IEC 27701:2019 (registro 74 251 0110/08), con Declaración de Aplicabilidad del 19 de abril de 2024, para sus servicios Virtual Hosting Enterprise y Virtual Hosting Standard. Es uno de los pocos casos documentados de certificación ISO/IEC 27701 en territorio peruano (Cirion Technologies, 2024).

Tabla 3. Organizaciones certificadas en ISO/IEC 27701. Elaboración propia a partir de las fuentes citadas.

Un rasgo común de los cuatro casos es que todos actúan como encargados del tratamiento: alojan o procesan datos personales por cuenta de sus clientes. Esto confirma que, en la práctica, la norma se ha usado sobre todo como instrumento de confianza en la cadena de suministro digital. Para una empresa peruana que contrate servicios en la nube, verificar que el proveedor tenga ISO/IEC 27701 es una forma concreta de cumplir el deber de diligencia en la elección del encargado que exige la Ley N.° 29733.

Parte III. Ensayo: la Ley de Protección de Datos Personales en el Perú

La seguridad de los datos de las personas en el Perú se regula principalmente mediante la Ley N.° 29733, Ley de Protección de Datos Personales, publicada en julio de 2011, cuyo objeto es garantizar el derecho fundamental reconocido en el numeral 6 del artículo 2 de la Constitución: que los servicios informáticos no suministren informaciones que afecten la intimidad personal y familiar. Este ensayo sostiene que la ley ha pasado de ser una norma de bajo impacto a un instrumento con capacidad real de sanción, pero que todavía protege más de lo que previene.

3.1. Contenido de la ley

La ley se construye sobre ocho principios rectores: legalidad, consentimiento, finalidad, proporcionalidad, calidad, seguridad, disposición de recurso y nivel suficiente de protección en las transferencias internacionales. El principio de seguridad obliga a quien trata datos a adoptar las medidas técnicas, organizativas y legales necesarias para evitar su alteración, pérdida o acceso no autorizado; es aquí donde la ley se conecta directamente con las prácticas de ISO/IEC 27001. A los titulares les reconoce los derechos de información, acceso, rectificación, cancelación, oposición y tratamiento objetivo, conocidos en conjunto como derechos ARCO. Las entidades que mantienen bancos de datos personales deben inscribirlos en el Registro Nacional de Protección de Datos Personales.

La autoridad competente es la Autoridad Nacional de Protección de Datos Personales (ANPD), que funciona dentro del Ministerio de Justicia y Derechos Humanos a través de la Dirección General de Transparencia, Acceso a la Información Pública y Protección de Datos Personales, conforme al Decreto Legislativo N.° 1353. Las infracciones se califican como leves, graves y muy graves, con multas que van de 0,5 hasta 100 unidades impositivas tributarias (UIT).

3.2. Aplicación en la actualidad

El cambio más importante de los últimos años es el nuevo Reglamento aprobado por el Decreto Supremo N.° 016-2024-JUS, publicado el 30 de noviembre de 2024 y vigente desde el 31 de marzo de 2025. El reglamento incorporó la obligación de designar un oficial de datos personales en determinados supuestos, la notificación obligatoria de incidentes de seguridad a la autoridad en un plazo de 48 horas, medidas de seguridad más exigentes y una calificación más severa de las infracciones (Payet, Rey, Cauvi, Pérez Abogados, 2026). Sus efectos ya son medibles: durante 2025 las fiscalizaciones aumentaron 55 % respecto del año anterior, nueve de cada diez se iniciaron por denuncia de los propios titulares, se registraron 8 339 bancos de datos (el triple que en 2024) y se notificaron 342 incidentes de seguridad (Payet, Rey, Cauvi, Pérez Abogados, 2026).

La evolución de las multas confirma una autoridad más activa: superaron los S/ 7,6 millones en 2023, alcanzaron S/ 13 424 590 en 2024 y sumaron más de S/ 11,3 millones en 2025 (Ministerio de Justicia y Derechos Humanos, 2025a, 2026). Sin embargo, la recaudación efectiva es mucho menor, en parte porque las empresas sancionadas se acogen a la reducción del 40 % por pronto pago; entre 2018 y 2025 se recaudaron alrededor de 12 millones de soles por multas (Autoridad Nacional de Protección de Datos Personales, 2026).

3.3. Casos en los que se aplicó la ley

Caso	Hechos	Decisión de la ANPD
Banco de Crédito del Perú (2025)	Recopilaba de forma excesiva datos biométricos faciales de usuarios, clientes o no, que usaban el Libro de Reclamaciones virtual, y los almacenaba en una base propia sin consentimiento válido.	Multas de 27 UIT y 36 UIT (casi S/ 300 000), confirmadas en segunda instancia; orden de eliminar los patrones biométricos y cesar su uso (Panamericana, 2025).
Alfin Banco S.A. (2025)	Usó datos de denunciantes (fecha de nacimiento, ubigeo, dirección, teléfono, situación laboral) recibidos de una central privada de riesgos sin demostrar el origen lícito de la recolección.	Multas por 139,32 UIT, aproximadamente S/ 669 000, confirmadas por las R. D. N.° 055-2025 y 059-2025-JUS/DGTAIPD (Gestión, 2025).
Dos universidades privadas (2025)	Emplearon datos personales para fines publicitarios sin el consentimiento de sus titulares.	Multas que suman 36,75 UIT, más de S/ 161 000 (Ministerio de Justicia y Derechos Humanos, 2025b).
Financiera Oh S.A. (2024)	Infracción grave en el tratamiento de datos de usuarios de servicios financieros.	Multa de 24,75 UIT, consentida en segunda instancia, con medidas correctivas (Ministerio de Justicia y Derechos Humanos, 2024a).

Caso	Hechos	Decisión de la ANPD
Telefónica del Perú S.A.A. (2023)	No atendió de manera reiterada los requerimientos de información de la autoridad.	Sanción por obstrucción de la fiscalización (Ministerio de Justicia y Derechos Humanos, 2024b).
Interbank (2024)	El banco reconoció que datos de un grupo de clientes fueron expuestos por un tercero; un atacante afirmó tener información de unos tres millones de clientes.	Fiscalización de oficio para verificar las medidas técnicas y organizativas de seguridad; Indecopi y la SBS iniciaron acciones paralelas (Forbes Perú, 2024; Andina, 2024).

Tabla 4. Casos de aplicación de la Ley N.° 29733. Elaboración propia a partir de las fuentes citadas.

3.4. ¿Ayuda la ley a la seguridad de los datos de las personas?

La respuesta es afirmativa, pero con matices. La ley ayuda en tres aspectos. Primero, convierte la protección de datos en una obligación exigible: los casos del BCP y de Alfin Banco muestran que ni las entidades más grandes están exentas y que la autoridad no solo multa, sino que ordena borrar datos y cambiar procesos. Segundo, el caso BCP sienta un criterio valioso de minimización: aunque validar la identidad sea legítimo, la entidad debe elegir el mecanismo menos intrusivo, un principio que tiene consecuencias directas para quienes diseñamos sistemas con reconocimiento facial o inteligencia artificial. Tercero, el nuevo reglamento introduce prácticas de gestión propias de los estándares internacionales, como la figura del oficial de datos y la notificación de incidentes, que acercan la ley a la lógica preventiva de ISO/IEC 27001 e ISO/IEC 27701.

Los límites también son claros. La mayoría de las fiscalizaciones empieza por denuncia, lo que significa que la autoridad actúa después del daño y depende de que el ciudadano sepa denunciar. Las filtraciones masivas de 2024 y 2025, como las de Interbank o la alerta sobre una base de datos de clientes de Inkafarma difundida por el Centro Nacional de Seguridad Digital, muestran que las sanciones no impiden que los datos ya expuestos circulen en foros delictivos (Perú Retail, 2025). Además, la distancia entre multas impuestas y recaudadas debilita el efecto disuasivo, y muchas pequeñas empresas aún desconocen sus obligaciones básicas, como inscribir sus bancos de videovigilancia o del libro de reclamaciones.

En conclusión, la Ley N.° 29733 sí contribuye a la seguridad de los datos personales en el Perú, sobre todo desde la entrada en vigor del nuevo reglamento, pero su eficacia depende de que las organizaciones la traduzcan en controles técnicos concretos. Para el ingeniero de sistemas, la ley no es un asunto exclusivo de abogados: define requisitos de diseño, como la minimización, el cifrado, el control de accesos, la trazabilidad y la capacidad de borrar datos, que deben estar presentes desde la arquitectura del sistema.

Parte IV. Plan de contingencia generado con IA y ajustado según los ODS y normas internacionales

4.1. Planteamiento y método

La inteligencia artificial generativa puede apoyar las prácticas de desarrollo sostenible y responsabilidad social en infraestructuras tecnológicas porque acelera la redacción de planes, propone escenarios y estructura información dispersa. Su límite es que produce respuestas plausibles, pero no necesariamente correctas, actualizadas ni adaptadas al contexto local. Por esa razón se aplicó un método de cinco pasos: (1) redactar un prompt; (2) obtener la propuesta inicial de la IA; (3) evaluarla contra los ODS y normas internacionales; (4) ajustarla; y (5) validar la priorización de riesgos con un programa en Python.

El caso de estudio es la infraestructura tecnológica de una institución educativa de Trujillo con un centro de datos propio (servidores, almacenamiento, red, climatización y UPS) y servicios en nube híbrida para unos 12 000 usuarios. La herramienta empleada fue Claude, asistente de IA generativa de Anthropic. El prompt utilizado fue el siguiente:

```
Actúa como especialista en continuidad del negocio y operaciones de TI. Genera una propuesta de Plan de
Contingencia para la infraestructura tecnológica de una institución educativa de Trujillo (Perú) que
tiene un centro de datos propio (servidores, almacenamiento, red, climatización y UPS) y servicios en
nube híbrida para unos 12 000 usuarios. El plan debe incluir: objetivo, alcance, escenarios de riesgo,
acciones de respuesta, responsables y pruebas. Considera prácticas de desarrollo sostenible y responsabi-
lidad social. Responde en español y en formato de documento.
```

El prompt se formuló de manera abierta, sin mencionar normas, ODS ni métricas, para observar qué incorpora la IA por sí sola y qué omite.

4.2. Propuesta inicial de la IA (versión 1)

La IA entregó un plan de ocho secciones. Su contenido se resume en la Tabla 5; el texto completo se conserva sin modificaciones en el repositorio.

Sección	Contenido generado
Objetivo y alcance	Garantizar la continuidad de los servicios tecnológicos; alcance: centro de datos, red, nube, plataforma académica, correo y sistemas administrativos.
Escenarios	Corte de energía, falla de hardware, ataque informático, incendio y caída de internet.
Respuesta	UPS y grupo electrógeno diésel; reemplazo de componentes; aislar equipos infectados y restaurar desde copias; extinción y traslado a sitio alterno; enlace de respaldo.
Responsables	Jefe de TI, administrador de servidores, administrador de redes y soporte técnico.
Sostenibilidad y responsabilidad social	Equipos con certificación de eficiencia energética, reciclaje de equipos dados de baja, reducción del papel y comunicación de interrupciones a la comunidad.
Pruebas y marco	Simulacros anuales; base en ISO/IEC 27001 «dominio A.17» e ITIL.

Tabla 5. Síntesis de la versión 1 generada por la IA.

4.3. Evaluación del resultado

La versión 1 tiene virtudes: una estructura clara, roles definidos y escenarios típicos de cualquier centro de datos. Sin embargo, al contrastarla con los ODS y con las normas aplicables se encontraron once deficiencias, resumidas en la Tabla 6.

N.º	Hallazgo en la versión 1	Referencia incumplida	Ajuste aplicado en la versión 2
1	Cita el «dominio A.17» de ISO/IEC 27001, numeración de la edición de 2013, ya sin certificados vigentes.	ISO/IEC 27001:2022, controles A.5.29, A.5.30, A.8.13 y A.8.14.	Referencias actualizadas a la edición 2022.
2	No hay análisis de impacto en el negocio ni tiempos objetivo de recuperación.	ISO 22301:2019, cláusula 8.2.2; ISO/IEC 27031.	Análisis de impacto con RTO y RPO por servicio.
3	Omite riesgos climáticos y naturales relevantes para la costa norte (lluvias por El Niño costero, sismo).	ISO/IEC 27001 Amd 1:2024; ODS 13, meta 13.1; ODS 11, meta 11.5.	Escenarios E2 y E7 con medidas de ubicación y protección física.
4	Los riesgos no se priorizan; todos parecen igual de importantes.	ISO/IEC 27001, cláusula 6.1.2; ISO 31000.	Matriz probabilidad × impacto calculada con un programa.

N.º	Hallazgo en la versión 1	Referencia incumplida	Ajuste aplicado en la versión 2
5	Depende del grupo electrógeno diésel sin criterio energético ni de emisiones.	ODS 7, meta 7.2 y 7.3; ODS 13; ISO 50001.	Respaldo híbrido, medición de consumo y hoja de ruta hacia energía solar con almacenamiento.
6	«Reciclar equipos» es genérico y no considera los datos que contienen.	ODS 12, meta 12.5; D. S. N.° 009-2019-MINAM (RAEE); ISO/IEC 27001 A.8.10 y A.7.14.	Borrado seguro certificado y entrega a operadores de RAEE autorizados.
7	«Restaurar desde copias» no protege contra ransomware que cifra también los respaldos.	ISO/IEC 27001 A.8.13; ISO/IEC 27035.	Regla de respaldo 3-2-1-1-0 con copia inmutable y fuera de línea.
8	No contempla la fuga de datos personales ni la notificación a la autoridad y a los titulares.	Ley N.° 29733 y D. S. N.° 016-2024-JUS (48 h); ISO/IEC 27701; ODS 16, meta 16.10.	Escenario E5 con protocolo de notificación y atención a titulares.
9	La responsabilidad social se reduce a «comunicar interrupciones».	ISO 26000; ODS 4, meta 4.1; ODS 10.	Continuidad académica, canales accesibles y atención prioritaria a usuarios vulnerables.
10	Sin indicadores ambientales del centro de datos.	ISO/IEC 30134-2 (PUE); ISO 14001.	Indicadores PUE, porcentaje de energía renovable y RAEE gestionados.
11	Pruebas «anuales» sin tipo, alcance ni criterio de éxito; omite a los proveedores de nube.	ISO 22301, cláusula 8.5; ISO/IEC 27001 A.5.23 y A.5.30.	Programa de ejercicios y cláusulas de continuidad con proveedores.

Tabla 6. Evaluación de la versión 1 frente a los ODS y las normas internacionales.

La evaluación muestra un patrón: la IA resolvió bien la parte operativa genérica, pero falló en lo que depende del contexto (clima y regulación peruana), de la vigencia de las normas (citó una numeración obsoleta) y de la medición. También trató la sostenibilidad y la responsabilidad social como un apartado decorativo al final, cuando deben estar integradas en cada decisión de respuesta. Ninguno de estos errores era evidente para un lector no especializado, lo que confirma que el resultado de una IA no debe usarse sin revisión experta.

4.4. Plan de contingencia ajustado (versión 2)

a) Objetivo

Mantener o restablecer, dentro de tiempos definidos, los servicios tecnológicos críticos de la institución ante incidentes disruptivos, protegiendo los datos personales de la comunidad educativa y reduciendo el impacto ambiental de la infraestructura, en coherencia con ISO 22301, ISO/IEC 27001:2022, la Ley N.° 29733 y los ODS 4, 7, 9, 12, 13 y 16.

b) Alcance y organización

Comprende el centro de datos principal, la red del campus, los enlaces de internet, los servicios en nube y los sistemas de la Tabla 7. La respuesta se organiza en un Comité de Crisis (dirección general, jefatura de TI, oficial de datos personales, comunicaciones y seguridad física), un Equipo de Respuesta Técnica (servidores, redes, seguridad de la información) y un Equipo de Apoyo (mantenimiento, proveedores y atención a usuarios). Cada rol tiene un titular y un suplente para cubrir el escenario de indisponibilidad de personal.

Servicio	Criticidad	RTO	RPO	Estrategia de recuperación
Plataforma académica (aula virtual, matrícula, notas)	Crítica	4 h	1 h	Réplica en nube y conmutación por error.
Identidad y autenticación (directorio, MFA)	Crítica	2 h	15 min	Controlador secundario en nube.
Correo y colaboración	Alta	8 h	4 h	Servicio en nube con continuidad del proveedor.
Sistemas administrativos y financieros	Alta	24 h	4 h	Restauración desde copia inmutable.
Portal web institucional	Media	24 h	24 h	Versión estática alterna en CDN.

Tabla 7. Análisis de impacto en el negocio: servicios, tiempos objetivo de recuperación (RTO) y punto objetivo de recuperación (RPO).

c) Evaluación y priorización de riesgos

Cada escenario se valoró con una escala de 1 a 5 de probabilidad e impacto. El programa *matriz_riesgos.py* calcula el nivel (P × I), lo clasifica (crítico ≥ 15; alto 10–14; medio 5–9; bajo < 5), ordena los escenarios y verifica que cada estrategia esté vinculada al menos a un ODS y a una norma. La Figura 1 y la Tabla 8 muestran su salida.

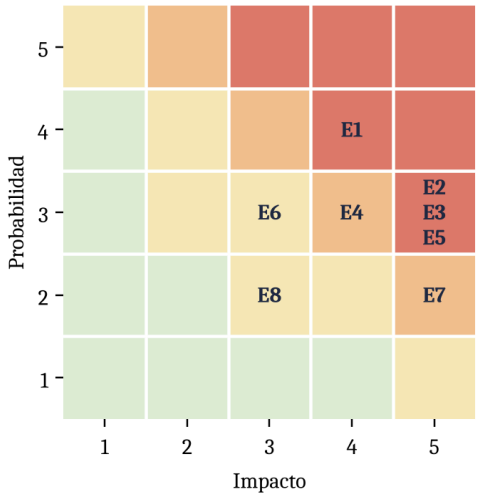


Figura 1. Mapa de calor de los escenarios de riesgo. Salida del programa matriz_riesgos.py.

ID	Escenario	P	I	Nivel	Clase	ODS	Normas de referencia
E1	Corte prolongado de energía eléctrica	4	4	16	Crítico	7, 9, 13	ISO 22301; ISO 50001; ISO/IEC 27001 A.7.11
E2	Lluvias intensas e inundación por El Niño costero	3	5	15	Crítico	9, 11, 13	ISO 22301; ISO/IEC 27001 Amd 1:2024 y A.7.5
E3	Ransomware sobre servidores y respaldos	3	5	15	Crítico	9, 16	ISO/IEC 27001 A.8.7 y A.8.13; ISO/IEC 27035
E5	Brecha o fuga de datos personales	3	5	15	Crítico	16, 9	Ley 29733 y D. S. 016-2024-JUS; ISO/IEC 27701
E4	Falla del sistema de climatización	3	4	12	Alto	7, 12, 13	ISO/IEC 30134-2; ISO 14001; ISO/IEC 27001 A.7.11
E7	Sismo de gran magnitud	2	5	10	Alto	11, 9	ISO 22301; ISO/IEC 27001 A.7.5; Ley 29664
E6	Caída del proveedor de nube o del enlace de internet	3	3	9	Medio	9, 17	ISO/IEC 27001 A.5.23 y A.5.30; ISO/IEC 27031
E8	Indisponibilidad de personal clave	2	3	6	Medio	8, 4	ISO 22301, cláusula 7.2; ISO/IEC 27001 A.6.3

Tabla 8. Matriz de riesgos priorizada. Resultado: cuatro escenarios críticos, dos altos y dos medios; ningún escenario quedó sin ODS o norma asociada.

d) Estrategias por escenario

Escenario	Prevención	Respuesta y recuperación	Criterio de sostenibilidad o responsabilidad social
E1 Energía	UPS dimensionadas para 30 min; mantenimiento trimestral del generador; medición del consumo por rack.	Apagado ordenado de cargas no críticas; conmutación de la plataforma académica a la nube si el corte supera 2 h.	Hoja de ruta hacia paneles solares con baterías; registro de horas y consumo del generador para reportar emisiones (ODS 7 y 13).
E2 Inundación	Equipos sobre piso técnico elevado; sensores de agua; revisión de drenajes antes de la temporada de lluvias.	Desenergizar la sala afectada; activar el sitio alterno en nube; inventario de daños.	Coordinación con la plataforma de defensa civil local; la continuidad de servicios apoya a la comunidad durante la emergencia (ODS 11 y 13).

Escenario	Prevención	Respuesta y recuperación	Criterio de sostenibilidad o responsabilidad social
E3 Ransomware	Parches, EDR, segmentación de red, MFA y copias 3-2-1-1-0 con una copia inmutable y otra fuera de línea.	Aislar segmentos; activar el protocolo de incidentes; restaurar desde copia limpia verificada; denuncia ante la Policía (Divindat).	No pagar rescates, para no financiar el delito; informar a la comunidad con transparencia (ODS 16).
E5 Fuga de datos	Cifrado, prevención de fuga de datos (A.8.12), mínimo privilegio y registro de accesos.	Contener; evaluar el alcance; notificar a la ANPD dentro de 48 h; informar a los titulares afectados con recomendaciones.	Atención prioritaria a estudiantes menores de edad y a personas vulnerables; lenguaje claro (ODS 16.10 e ISO 26000).
E4 Climatización	Redundancia N+1; contención de pasillo frío; alarmas de temperatura.	Ventilación de emergencia; reducción temporal de carga; traslado de cargas a la nube.	Meta de PUE ≤ 1,6; free cooling aprovechando el clima costero; refrigerantes de bajo potencial de calentamiento (ODS 7, 12 y 13).
E7 Sismo	Anclaje de racks; inspección estructural; copias geográficamente separadas.	Evacuación según protocolo; evaluación de daños; recuperación desde la nube.	Simulacros integrados con los de seguridad de las personas (ODS 11.5).
E6 Nube o enlace	Dos proveedores de internet; contratos con cláusulas de continuidad y portabilidad de datos.	Conmutar al enlace alterno; modo degradado de servicios.	Preferir proveedores con metas públicas de energía renovable y certificación ISO/IEC 27701 (ODS 9 y 17).
E8 Personal	Titular y suplente por rol; procedimientos documentados; capacitación cruzada.	Activar suplentes; apoyo del proveedor con acuerdo de nivel de servicio.	Carga de trabajo razonable y turnos durante crisis prolongadas (ODS 8).

Tabla 9. Estrategias de prevención, respuesta y recuperación con criterio de sostenibilidad.

e) Gestión del equipamiento al final de su vida útil

Todo equipo dado de baja pasa por tres pasos: borrado seguro o destrucción de los medios de almacenamiento con acta de evidencia (ISO/IEC 27001, controles A.7.14 y A.8.10); reutilización o donación a instituciones educativas cuando el equipo aún es funcional; y, en su defecto, entrega a una empresa operadora de residuos de aparatos eléctricos y electrónicos autorizada, conforme al D. S. N.º 009-2019-MINAM. Este procedimiento une seguridad y sostenibilidad: evita que un disco reciclado se convierta en una fuga de datos personales y reduce los residuos electrónicos (ODS 12.5).

f) Comunicación y responsabilidad social

Ante una interrupción se informa a estudiantes, docentes y personal por al menos dos canales independientes (correo, redes sociales oficiales y mensajería). Los mensajes indican qué servicio está afectado, el tiempo estimado de recuperación y la alternativa disponible, como la ampliación de plazos de evaluaciones para que ningún estudiante sea perjudicado (ODS 4). Los comunicados usan lenguaje claro y formatos accesibles. Cuando hay datos personales comprometidos, el oficial de datos personales coordina la notificación a la autoridad y a los titulares.

g) Pruebas, mantenimiento e indicadores

Ejercicio o indicador	Frecuencia	Criterio de éxito o meta
Restauración de copias de seguridad	Mensual	Restauración íntegra dentro del RPO; 0 errores en la verificación.
Ejercicio de mesa del Comité de Crisis	Semestral	Decisiones clave tomadas en menos de 30 min; lecciones registradas.
Conmutación a la nube (E1, E2, E7)	Anual	Plataforma académica disponible dentro del RTO de 4 h.
Simulacro de fuga de datos (E5)	Anual	Notificación a la autoridad preparada en menos de 48 h.
PUE del centro de datos	Mensual	≤ 1,6 a dos años, medido según ISO/IEC 30134-2.
Energía de fuentes renovables	Anual	Incremento progresivo hasta 30 % a cinco años.
RAEE gestionados con operador autorizado	Anual	100 %, con actas de borrado seguro.
Revisión integral del plan	Anual o tras cada incidente mayor	Plan actualizado y aprobado por la dirección.

Tabla 10. Programa de pruebas e indicadores del plan.

4.5. Valoración del uso de la IA

La experiencia confirma que la IA sí puede ayudar a incorporar el desarrollo sostenible y la responsabilidad social en las infraestructuras tecnológicas, pero como asistente y no como autor final. Su aporte fue la velocidad: produjo en segundos una estructura que habría tomado horas. Su debilidad fue la falta de contexto y de verificación: omitió los riesgos climáticos de la región, la obligación peruana de notificar incidentes y los indicadores ambientales, y citó una numeración normativa obsoleta. El valor del ingeniero está en la evaluación crítica, en el conocimiento de las normas vigentes y en la capacidad de medir. El ciclo prompt, evaluación, ajuste y validación con código es una práctica replicable para cualquier documento técnico apoyado por IA.

Parte V. Los ODS y el propósito de la carrera de Ingeniería de Sistemas e Inteligencia Artificial

Los Objetivos de Desarrollo Sostenible forman parte de la Agenda 2030, aprobada por la Asamblea General de las Naciones Unidas en septiembre de 2015. Son 17 objetivos y 169 metas que integran las dimensiones económica, social y ambiental del desarrollo, bajo el principio de «no dejar a nadie atrás» (Naciones Unidas, 2015). Aunque solo el ODS 9 menciona de forma explícita la infraestructura y la innovación, la tecnología es un medio transversal para alcanzar todos los demás.

El propósito de la carrera de Ingeniería de Sistemas e Inteligencia Artificial es formar profesionales que diseñen, desarrollen y gestionen sistemas de información y soluciones de inteligencia artificial que resuelvan problemas reales de las organizaciones y de la sociedad, de manera ética, segura y sostenible. La Tabla 11 muestra cómo ese propósito se alinea con cada ODS.

ODS	Alineación con la carrera y aporte concreto del ingeniero
1. Fin de la pobreza	Sistemas de focalización de programas sociales con datos integrados y modelos que reduzcan errores de inclusión y exclusión; plataformas de inclusión financiera y billeteras digitales.
2. Hambre cero	Agricultura de precisión con sensores IoT, imágenes satelitales y modelos predictivos de cosecha; trazabilidad de cadenas de suministro de alimentos.
3. Salud y bienestar	Historia clínica electrónica interoperable, telemedicina y modelos de apoyo al diagnóstico, siempre con protección de datos sensibles.
4. Educación de calidad	Plataformas de aprendizaje, tutores inteligentes y analítica del aprendizaje para detectar a tiempo el riesgo de deserción.
5. Igualdad de género	Auditoría de sesgos en algoritmos de selección y crédito; promoción de la participación de mujeres en tecnología; canales digitales seguros de denuncia de violencia.
6. Agua limpia y saneamiento	Telemetría de redes de agua, detección de fugas con IA y sistemas de alerta de calidad del agua.
7. Energía asequible y no contaminante	Redes eléctricas inteligentes, pronóstico de generación renovable y diseño de software y centros de datos energéticamente eficientes.
8. Trabajo decente y crecimiento económico	Transformación digital de las mipymes, automatización que libere a las personas de tareas repetitivas y emprendimientos de base tecnológica.
9. Industria, innovación e infraestructura	Núcleo de la carrera: infraestructura de TI resiliente, arquitecturas en la nube, ciberseguridad e investigación aplicada en IA.
10. Reducción de las desigualdades	Diseño accesible e inclusivo, servicios en lenguas originarias y cierre de brechas digitales entre zonas urbanas y rurales.
11. Ciudades y comunidades sostenibles	Ciudades inteligentes, gestión del tránsito, sistemas de alerta temprana ante desastres como El Niño costero y gobierno digital municipal.
12. Producción y consumo responsables	Gestión responsable de residuos electrónicos, economía circular de equipos y optimización de inventarios para reducir desperdicios.
13. Acción por el clima	Modelos climáticos, medición de la huella de carbono de la infraestructura digital y planes de continuidad que consideren riesgos climáticos.
14. Vida submarina	Monitoreo satelital de la pesca ilegal y analítica de datos oceanográficos para la gestión sostenible del mar peruano.
15. Vida de ecosistemas terrestres	Detección de deforestación y minería ilegal con visión por computadora sobre imágenes satelitales.
16. Paz, justicia e instituciones sólidas	Ciberseguridad, protección de datos personales, transparencia, datos abiertos y apoyo tecnológico a la investigación de ciberdelitos; IA ética y explicable.
17. Alianzas para lograr los objetivos	Interoperabilidad entre entidades, estándares abiertos, cooperación universidad-empresa-Estado y transferencia de conocimiento.

Tabla 11. Alineación de los 17 ODS con el propósito de la carrera.

La alineación permite extraer una conclusión: la carrera contribuye a los ODS de dos maneras. De forma directa, en los objetivos donde la tecnología es el producto (ODS 9, 4 y 16); y de forma habilitadora, en los demás, donde los sistemas y la IA son el medio para medir, predecir y decidir mejor. En ambos casos, la contribución solo es positiva si la tecnología es segura, protege la privacidad y no reproduce sesgos, que es precisamente la intersección entre ética, seguridad de datos y desarrollo sostenible que aborda este trabajo.

Parte VI. Ensayos sobre el Informe Defensorial «La ciberdelincuencia en el Perú: estrategias y retos del Estado»

El Informe de Adjuntía N.° 001-2023-DP/ADHPD, elaborado por la Defensoría del Pueblo y firmado digitalmente en mayo de 2023, presenta un diagnóstico de la ciberdelincuencia en el país y evalúa la actuación de la Policía Nacional, el Ministerio Público y el Poder Judicial frente a ella. Los ensayos siguientes analizan sus dos primeros capítulos.

6.1. Ensayo del Capítulo I: Marco teórico de la ciberdelincuencia

Un delito sin fronteras que exige entender primero la tecnología

El Capítulo I parte de una constatación honesta: no existe una definición consensuada de ciberdelincuencia. Para suplir ese vacío, la Defensoría recurre a la Oficina de las Naciones Unidas contra la Droga y el Delito (Unodc), que la entiende como el conjunto de actos que infringen la ley usando las tecnologías de la información y la comunicación (TIC), ya sea para atacar redes, sistemas y datos o para facilitar un delito, y que se diferencia de la delincuencia común porque no tiene barreras físicas ni geográficas y se comete con menos esfuerzo y mayor velocidad (Defensoría del Pueblo, 2023). Mi tesis es que el principal aporte de este capítulo no es la definición, sino demostrar que la ciberdelincuencia crece al mismo ritmo que nuestra dependencia digital y que, por ello, combatirla requiere tanto conocimiento tecnológico como jurídico.

El informe sustenta esa dependencia con datos del INEI: entre 2010 y 2022 la proporción de peruanos de seis años a más que usa internet pasó del 35 % al 73 %, el uso diario se elevó del 34 % al 93 % y el celular se convirtió en el principal medio de acceso, del 22 % al 67 % en seis años. La pandemia aceleró este proceso al trasladar al ciberespacio el trabajo, la educación y los trámites. La consecuencia es lo que el texto denomina una tensión entre el libre uso de la tecnología y la protección del patrimonio y el bienestar de las personas: cuanto más vivimos en línea, más expuestos estamos.

Una distinción conceptual especialmente útil es la que separa los ciberdelitos puros de los delitos facilitados por la tecnología. Los primeros tienen a las TIC como blanco y protegen la información en sus tres pilares: confidencialidad, integridad y disponibilidad. Para un estudiante de Ingeniería de Sistemas, esta referencia resulta familiar, porque es la misma tríada que fundamenta ISO/IEC 27001; el derecho penal y la seguridad de la información protegen, en el fondo, el mismo bien. Los segundos son delitos tradicionales, como la estafa o el acoso, en los que la tecnología solo es el medio. El informe advierte con acierto que el mero uso de un dispositivo no convierte un delito común en ciberdelito, pero que sí cambia sus condiciones: anonimato, inmediatez, masividad, internacionalidad y dificultad para obtener evidencia digital.

El capítulo describe además la ciberdelincuencia como una industria organizada. Siguiendo al FBI, identifica diez roles: programadores de malware, distribuidores de datos robados, técnicos que sostienen la infraestructura, hackers que buscan vulnerabilidades, defraudadores que aplican ingeniería social, proveedores de alojamiento ilícito, vendedores de cuentas, muleros, lavadores de activos y líderes. Esta división del trabajo explica por qué casos recientes en el Perú, como las filtraciones de bases de datos de clientes de bancos y cadenas comerciales, terminan en foros donde la información se vende: el ataque es solo un eslabón de una cadena económica. A ello se suman los factores identificados por Interpol, como la conectividad de personas con baja cultura de seguridad, la movilidad, la proliferación de dispositivos conectados, la sofisticación de los atacantes, el subregistro por falta de denuncia y la complejidad de las investigaciones transfronterizas.

El punto más sensible del capítulo es el riesgo para niñas, niños y adolescentes. Según las encuestas citadas, los padres que perciben un mayor riesgo de explotación sexual en línea de sus hijos pasaron del 25 % al 62 % entre 2018 y 2021, y un tercio no sabe dónde denunciar. Además, solo el 16 % recibió de su proveedor de internet la oferta de filtros de contenido que la ley obliga a informar. El informe subraya que estos delitos producen daños profundos y duraderos y que la víctima es revictimizada cada vez que alguien accede al material. Aquí la tecnología no es neutral: el diseño de plataformas, los mecanismos de denuncia y la moderación de contenidos son decisiones de ingeniería con consecuencias éticas directas.

Finalmente, el capítulo dimensiona el impacto económico, con estimaciones de daños mundiales que pasaron de 3 a 6 billones de dólares entre 2015 y 2021, y la pérdida de confianza en la economía digital. Como crítica, el marco teórico se apoya en cifras de 2021 y 2022 que hoy han sido superadas, y dedica poco espacio a amenazas que en los años siguientes ganaron peso, como el ransomware contra organizaciones o el fraude potenciado por inteligencia artificial. Aun así, el capítulo cumple su función: deja claro que la ciberdelincuencia es un fenómeno estructural, ligado a la transformación digital, y no un problema marginal. Para quienes diseñamos sistemas, la lección es que la seguridad no puede añadirse al final: debe ser un requisito desde el diseño.

6.2. Ensayo del Capítulo II: Marco normativo contra la ciberdelincuencia

Leyes que avanzan detrás de la tecnología

El Capítulo II revisa cómo el derecho internacional y el peruano han respondido a la ciberdelincuencia. Su recorrido permite sostener una tesis clara: el Perú ha construido un marco penal razonablemente completo y alineado con el estándar internacional,

pero lo ha hecho de forma reactiva y fragmentada, y la ley por sí sola no garantiza la persecución eficaz de estos delitos.

En el plano internacional, el eje es el Convenio sobre la Ciberdelincuencia del Consejo de Europa, conocido como Convenio de Budapest, adoptado el 23 de noviembre de 2001. Es el instrumento más completo en la materia y actúa en tres frentes: el derecho penal sustantivo, al pedir que se tipifiquen los delitos contra la confidencialidad, integridad y disponibilidad de sistemas y datos, el fraude y la falsificación informáticos, la pornografía infantil y las infracciones a la propiedad intelectual; el derecho procesal, al prever la conservación rápida de datos, las órdenes de presentación, el registro y la obtención en tiempo real; y la cooperación internacional, mediante la extradición, la asistencia mutua y la Red 24/7. El Perú se adhirió mediante la Resolución Legislativa N.° 30913 y el Decreto Supremo N.° 010-2019-RE, y el convenio entró en vigor para el país el 1 de diciembre de 2019 (Defensoría del Pueblo, 2023).

El informe señala una deuda importante: a la fecha de su publicación, el Perú no se había adherido a ninguno de los dos protocolos adicionales. El primero, de 2003, sanciona la difusión de material racista y xenófobo; el segundo, de 2022, es el más relevante en la práctica, porque permite la cooperación directa con proveedores de servicios extranjeros para obtener datos de abonados y de tráfico, y la cooperación inmediata en emergencias. Dado que la mayoría de plataformas que usan los peruanos están alojadas fuera del país, no contar con este mecanismo significa investigaciones más lentas y evidencia que se pierde. El capítulo también menciona la negociación de una convención de las Naciones Unidas; ese proceso culminó con la aprobación de la Convención contra la Ciberdelincuencia por la Asamblea General en diciembre de 2024 y su apertura a la firma en Hanói en octubre de 2025, donde más de sesenta países la suscribieron (DPL News, 2025), lo que confirma la tendencia hacia un régimen global.

En el plano nacional, el capítulo reconstruye una evolución en tres etapas. La primera es la respuesta penal inicial: el Código Penal de 1991 ya tipificaba el hurto telemático, y la Ley N.° 27309 del año 2000 incorporó los delitos informáticos de acceso indebido y daño a bases de datos, a los que en 2013 se sumó el tráfico ilegal de datos. La segunda es la Ley N.° 30096, Ley de Delitos Informáticos, de octubre de 2013, modificada por la Ley N.° 30171 en 2014 para adecuarla al Convenio de Budapest. Esta ley organiza los ciberdelitos según el bien jurídico protegido: los datos y sistemas (acceso ilícito, atentados contra la integridad de datos y sistemas, abuso de dispositivos), la indemnidad sexual (proposiciones sexuales a menores por medios tecnológicos), la intimidad (interceptación de datos), el patrimonio (fraude informático) y la fe pública (suplantación de identidad). La tercera etapa es la incorporación al Código Penal de delitos facilitados por la tecnología, como el acoso y el chantaje sexual, la difusión no consentida de imágenes íntimas, la intervención de mensajería instantánea y la clonación de celulares. A ello se suma la Ley N.° 29733 de Protección de Datos Personales, de 2011, que opera en la vía administrativa.

El mérito del capítulo es que no se limita a enumerar normas, sino que recoge críticas técnicas. Por ejemplo, cita la observación de que el acceso ilícito sanciona por igual el mero intrusismo y el hacking con fines de lucro o daño, y que el atentado a la integridad de datos se castiga aunque no cause un daño grave. También advierte que el *grooming* en línea y el que se comete por otros medios están en normas distintas y son investigados por fiscalías diferentes, una duplicidad que puede perjudicar a las víctimas. Estas observaciones muestran que la dispersión normativa, con delitos repartidos entre una ley especial y múltiples artículos del Código Penal, dificulta la aplicación coherente.

El último apartado, sobre los procedimientos frente a la evidencia digital, es el más cercano a la ingeniería. El país cuenta con el Manual de Evidencia Digital de 2017, el Manual para el Recojo de la Evidencia Digital del Ministerio del Interior de 2019 y la Guía de Análisis Digital Forense del Ministerio Público de 2020, que regulan la cadena de custodia desde la identificación hasta la disposición final. Sin embargo, como muestran los capítulos posteriores del informe, las unidades policiales enfrentan carencias de personal especializado, equipos y software. Allí reside la conclusión principal: una ley moderna sin capacidad técnica para investigar se queda en el papel. El reto no es solo legislar mejor, sino formar profesionales capaces de preservar evidencia, rastrear operaciones y cooperar con proveedores internacionales, un campo en el que la Ingeniería de Sistemas e Inteligencia Artificial tiene un papel insustituible.

Conclusiones

ISO/IEC 27001 e ISO/IEC 27701 son complementarias: la primera protege la información en general mediante la gestión de riesgos y la segunda se centra en los datos personales y en los roles de responsable y encargado. La edición 2025 de ISO/IEC 27701, al independizarse de ISO/IEC 27001, facilitará su adopción, que hoy se concentra en proveedores de nube y centros de datos; en el Perú, el caso de Cirion Technologies muestra que ya existe capacidad local para certificarla.

La Ley N.° 29733 y su nuevo reglamento sí contribuyen a la seguridad de los datos de las personas, como lo demuestran las sanciones al BCP, a Alfin Banco y a universidades privadas, y el aumento de fiscalizaciones e incidentes notificados en 2025. Su eficacia, sin embargo, sigue siendo más reactiva que preventiva, porque depende de las denuncias y de que las organizaciones traduzcan las obligaciones legales en controles técnicos.

La IA generativa es útil para elaborar planes de contingencia sostenibles, pero su primera respuesta omitió riesgos locales, obligaciones legales e indicadores, y citó normas desactualizadas. Solo después de evaluarla frente a los ODS y a normas como ISO 22301, ISO/IEC 27001:2022 e ISO/IEC 30134-2, y de validar la priorización con un programa, se obtuvo un plan verificable. Los ODS, por su parte, encuentran en la carrera de Ingeniería de Sistemas e Inteligencia Artificial un aliado directo en los objetivos 4, 9 y 16 y habilitador en todos los demás.

Finalmente, el Informe Defensorial demuestra que la ciberdelincuencia crece con la digitalización y que el Perú cuenta con un marco penal alineado con el Convenio de Budapest, pero con pendientes en cooperación internacional y en capacidad técnica de investigación. La ética y la seguridad de los datos no son temas separados: proteger la información de las personas es, al mismo tiempo, un requisito legal, una buena práctica de ingeniería y una condición para el desarrollo sostenible.

Enlace de la solución

El repositorio contiene el prompt utilizado, la versión 1 del plan generada por la IA sin modificaciones, la evaluación, la versión 2 ajustada, los datos de los escenarios y el programa *matriz_riesgos.py* con sus salidas:

https://github.com/JuanDiegoCJ/SII-S11-Etica-Seguridad-Datos

Para ejecutar el programa se requiere Python 3.10 o superior y la biblioteca matplotlib: *python src/matriz_riesgos.py*.

Referencias

A-LIGN. (s. f.). *ISO 27701 updates: What you need to know*. https://www.a-lign.com/articles/iso-27701-updates-what-you-need-to-know

AFNOR. (s. f.). *ISO 27001 standard, IT partner for twenty years*. https://www.afnor.org/en/news/cybersecurity/iso-27001-standard-it-partner-for-twenty-years/

Amazon Web Services. (s. f.). *ISO/IEC 27701:2019 compliance*. https://aws.amazon.com/compliance/iso-27701-faqs/

Andina. (s. f.-a). *Inacal fortalece gestión de la seguridad de la información ISO 27001*. https://andina.pe/ingles/noticia-inacal-fortalece-gestion-de-seguridad-de-informacion-iso-27001-889599.aspx

Andina. (s. f.-b). *OSCE obtiene certificación en Seguridad de la Información – ISO 27001*. https://andina.pe/agencia/noticia-osce-obtiene-certificacion-seguridad-de-informacion-––iso-27001-887662.aspx

Andina. (2024, 3 de noviembre). *¿Filtraron tus datos bancarios? Estos son los pasos que debes seguir para evitar robos*. https://andina.pe/agencia/noticia-filtraron-tus-datos-bancarios-estos-son-los-pasos-debes-seguir-para-evitar-robos-1005885.aspx

Autoridad Nacional de Protección de Datos Personales. (2026). *Balance de gestión 2018-2025*. https://cdn.www.gob.pe/uploads/document/file/9351482/7666109-balance-de-gestion-2018-2025-autoridad-nacional-de-proteccion-de-datos-personales-anpd%282%29.pdf

Bright Defense. (2026). *ISO 27001: What changed in 2026?* https://www.brightdefense.com/news/iso-27001-what-changed-in-2026/

Cámara de Comercio de Lima. (s. f.). *Yarkan obtiene la certificación internacional ISO 27001 para fortalecer la seguridad de la información*. CCL Conectados. https://lacamara.pe/?p=101906

Cirion Technologies. (2024). *Certificado ISO/IEC 27701:2019, Cirion Technologies Peru S.A., LIM1*. https://lp.ciriontechnologies.com/hubfs/Other%20Files/Cirion%20Documentation/Certifications/Data-center/ISO27701-ANAB/PER%20-%20LIM1%20-%20ISO27701%20ESP.pdf

Coalfire. (2026, 17 de abril). *ISO/IEC 27701:2025 — The standalone privacy information management system is here*. https://coalfire.com/the-coalfire-blog/iso-iec-277012025-the-standalone-privacy-information-management-system-is-here-with-more-control-than-ever-before

Defensoría del Pueblo. (2023). *La ciberdelincuencia en el Perú: estrategias y retos del Estado* (Informe de Adjuntía N.° 001-2023-DP/ADHPD). Defensoría del Pueblo.

DNV. (s. f.). *Revision of ISO/IEC 27701*. https://www.dnv.com/assurance/Management-Systems/new-iso/transition/revision-of-iso-iec-27701/

DPL News. (2025). *65 países firman primer tratado global contra la ciberdelincuencia*. https://dplnews.com/?p=293920

Forbes Perú. (2024, 31 de octubre). *Interbank: Justicia inició investigación sobre filtración de datos de clientes*. https://forbes.pe/actualidad/2024-10-31/interbank-justicia-inicio-investigacion-sobre-filtracion-de-datos-de-clientes/

Gestión. (s. f.). *Tkambio obtiene certificación ISO 27001 y refuerza seguridad en su casa de cambio digital*. https://gestion.pe/empresasg/tkambio-obtiene-certificacion-iso-27001-y-refuerza-seguridad-en-su-casa-de-cambio-digital-noticia/

Gestión. (2025, 4 de septiembre). *Minjusdh sancionó a Alfin Banco por uso indebido de datos personales: ¿De cuánto es la multa?* https://gestion.pe/economia/empresas/minjusdh-sanciono-a-alfin-banco-por-uso-indebido-de-datos-personales-de-cuanto-es-la-multa-noticia/

Google Cloud. (2020, 30 de junio). *Reinforcing our commitment to privacy with accredited ISO/IEC 27701 certification*. https://cloud.google.com/blog/products/identity-security/google-cloud-certified-as-a-data-processor

Google Cloud. (s. f.). *ISO/IEC 27701*. https://cloud.google.com/security/compliance/iso-27701

ISMS.online. (s. f.). *What's new in ISO 27701:2025*. https://www.isms.online/iso-27701/whats-new-in-iso-27701-2025/

Kyndryl. (2024). *Certificado ISO/IEC 27001:2022, Kyndryl Peru S.A.C.* https://kyndryl.com/content/dam/kyndrylprogram/certifications/iso27001/kyndryl_peru_iso_27001_2022_03_feb_2028.pdf

Linford & Co. (2026, 21 de octubre). *ISO/IEC 27701:2025: What changed, what it means for certification, & what auditors are already seeing*. https://linfordco.com/?p=23924

Microsoft. (2020). *Azure is now certified for the ISO/IEC 27701 privacy standard*. https://azure.microsoft.com/en-au/blog/azure-is-now-certified-for-the-iso-iec-27701-privacy-standard/

Ministerio de Justicia y Derechos Humanos. (2024a). *MINJUSDH protege datos personales de usuarios de entidades financieras a través de la Autoridad Nacional de Protección de Datos Personales*. https://www.gob.pe/institucion/minjus/noticias/985720

Ministerio de Justicia y Derechos Humanos. (2024b, 2 de octubre). *MINJUSDH impuso sanciones a empresas por obstruir fiscalización al cumplimiento de la Ley de Protección de Datos Personales y su reglamento*. https://www.gob.pe/institucion/minjus/noticias/1032937

Ministerio de Justicia y Derechos Humanos. (2025a). *Autoridad Nacional de Protección de Datos Personales impuso multas por más de S/ 13 millones por infracciones a la normativa el año 2024*. https://www.gob.pe/institucion/minjus/noticias/1088896

Ministerio de Justicia y Derechos Humanos. (2025b, 5 de septiembre). *MINJUSDH sanciona a dos universidades por emplear datos personales para fines publicitarios sin consentimiento*. https://www.gob.pe/institucion/minjus/noticias/1239735

Ministerio de Justicia y Derechos Humanos. (2026). *ANPD impuso multas por más de S/ 11 millones y reforzó la protección de datos personales durante el 2025*. https://www.gob.pe/institucion/minjus/noticias/1331848

Naciones Unidas. (2015). *Transformar nuestro mundo: la Agenda 2030 para el Desarrollo Sostenible* (A/RES/70/1). Asamblea General de las Naciones Unidas.

Panamericana. (2025, 6 de enero). *Sancionan a BCP con casi S/ 300,000 por inadecuado tratamiento de datos personales biométricos solicitados a sus usuarios*. https://panamericana.pe/politica/431842-sancionan-bcp-casi-s-300-000-inadecuado-tratamiento-datos-personales-biometricos-solicitados-usuarios

Payet, Rey, Cauvi, Pérez Abogados. (2026). *A un año de la entrada en vigor del Nuevo Reglamento de Ley de Protección de Datos Personales: ¿Cuáles han sido sus efectos?* [Client memo]. https://prcp-r2-prd.postedin.com/Client-Memo-Nuevo-Reglamento-de-Ley-de-Proteccion-de-Datos-Personales-1-2.pdf

Perú Retail. (2025, 28 de febrero). *Filtración de datos en Inkafarma: la empresa responde tras alerta del Gobierno*. https://www.peru-retail.com/filtracion-de-datos-en-inkafarma-la-empresa-responde-tras-alerta-del-gobierno/

Pontificia Universidad Católica del Perú. (2026). *Programa Sistemas de gestión de seguridad de la información, protección de datos personales y privacidad*. Instituto para la Calidad. https://calidad.pucp.edu.pe/wp-content/uploads/2026/07/BT-ISO27.pdf

Revista Economía. (s. f.). *Rextie obtiene certificación ISO 27001 que garantiza un sistema óptimo de seguridad de la información*. https://www.revistaeconomia.com/?p=55695

Speeki. (s. f.). *Get ISO 27001 certification*. https://www.speeki.com/get-iso-27001-certification